Avaliação de Privacidade e Segurança da Informação - Respostas para OneTrust (Pottencial Seguradora)

Este documento contém as respostas sugeridas para preenchimento do formulário da OneTrust da Pottencial Seguradora. **Nota Estratégica:** Como a Perceptiva fornece soluções de infraestrutura (API Gateway / Kong) e conectividade, as respostas estão formuladas focando no fato de que **não armazenamos, processamos nem controlamos os dados de negócio (incluindo dados pessoais)** que trafegam pelo gateway. Nosso papel restringe-se ao processamento de telemetria técnica e logs de auditoria sistêmica anonimizados.

---

1. Informações Gerais

ID	Pergunta	Resposta Sugerida
1.1	Qual o nome da sua empresa?	Perceptiva.
1.2	Quanto tempo a empresa está no mercado?	*(Preencher com o tempo correto, ex: 5 anos)*.
1.3	Quantos funcionários a empresa possui?	*(Preencher com o número aproximado, ex: 11-50 funcionários)*.
1.4	Quais são os países que a empresa opera?	Brasil *(e outros aplicáveis, ex: Estados Unidos)*.
1.5	Descreva de forma detalhada, qual o tipo de prestação de serviço que será fornecida à Pottencial Seguradora S/A.	A Perceptiva atua como fornecedora de infraestrutura de conectividade e gerenciamento de APIs (Gateway / Kong). A solução provê roteamento seguro, aplicação de políticas de segurança de rede (Rate Limiting, autenticação de endpoints) e observabilidade do tráfego. Nossa infraestrutura atua como "pass-through" (repasse) para os payloads das APIs e **não armazena nem realiza o tratamento prolongado ou em repouso dos dados de negócio ou dados pessoais** dos clientes da Pottencial Seguradora.

---

2. Privacidade e Proteção de Dados

ID	Pergunta	Resposta Sugerida
2.1	Se firmada, sua parceria com a Pottencial Seguradora irá efetuar tratamento de dados pessoais?	**Não.** Nossa solução atua exclusivamente como camada de infraestrutura de rede (API Gateway). Os payloads passam de forma efêmera pelo sistema para fins de roteamento, não havendo armazenamento ou análise. O processamento sistêmico é focado em cabeçalhos (headers) criptografados e metadados de tráfego (telemetria).
2.3	Haverá tratamento de dados pessoais sensíveis?	**Não.**

2.5	Os dados pessoais obtidos da Pottencial serão compartilhados com terceiros?	**Não se aplica.** Não obtemos nem controlamos dados pessoais em nossas bases.
2.7	Sua empresa possui Política de Privacidade e Proteção de Dados estabelecida?	**Sim.** *(Ver anexo: Política de Privacidade e Proteção de Dados)*.
2.9	Sua empresa possui processos para registrar as atividades que processam dados pessoais? (Data Mapping)	**Sim.** O inventário cobre os dados B2B. Em relação à plataforma, possuímos mapeamento formal atestando a isenção do tratamento de dados de clientes na infraestrutura do Gateway. *(Anexar o documento de Política gerado)*.
2.10	Inserir evidência para a resposta da pergunta anterior	*Ação: Upload do PDF da* `politica_privacidade_protecao_dados` *gerada (contendo a Declaração de Isenção de Tratamento)*.
2.11	Sua empresa possui um processo previsto e operante para realização de análises de impacto à privacidade (DPIA)?	**Sim.** Apesar de não tratarmos dados pessoais no escopo contratado (pass-through), possuímos o processo documentado em nossa Política de Privacidade caso o escopo sistêmico evolua.
2.12	Sua empresa possui um processo estabelecido e operante para atendimento aos direitos dos titulares de dados pessoais?	**Sim.** Caso um titular envie uma requisição para a Perceptiva, nosso processo estabelece a pronta resposta informando que somos estritamente fornecedores de infraestrutura B2B e o imediato redirecionamento do titular para o Controlador de Dados adequado.
2.14	Sua empresa modificará os dados pessoais compartilhados pela Pottencial, combinando-os com outros dados, ou utilizará para alguma finalidade específica?	**Não.**
2.15	Sua empresa mantém um registro com a localização do armazenamento de dados pessoais ou um fluxograma...?	**Sim.** Mantemos o mapa da arquitetura em nuvem (Fluxograma) o qual evidencia o isolamento da rede B2B; contudo, corroboramos novamente que a infraestrutura contratada **não armazena dados pessoais em repouso**.
2.17	Sua empresa coleta apenas o mínimo necessário de dados pessoais para o tratamento...? (princípio de minimização)	**Sim.** Seguimos o princípio de minimização à risca (Privacy by Design). Coletamos apenas as métricas não-pessoais necessárias para a monitoração de uptime e latência da infraestrutura (logs técnicos anonimizados).
2.18	Sua empresa garante que os dados/informações passados pela Pottencial não serão tratados para outras especificações além do solicitado/acordado?	**Sim.** Garantimos restritamente a finalidade contratual.

2.19	Sua empresa possui políticas e procedimentos gerais em relação ao uso secundário de dados pessoais?	**Sim.** Nossa Política proíbe expressamente o uso secundário sistêmico de qualquer tráfego cliente processado na rede privativa.
2.20	Inserir evidência para a resposta da pergunta anterior	*Ação: Upload novamente do PDF da* `politica_privacidade_protecao_dados` *ou da* `politica_seguranca_informacao`*.*
2.21	Sua empresa está obrigada a realizar alguma atividade de tratamento de dados pessoal por força de obrigação legal ou regulatória?	**Não** no âmbito da prestação de serviços à Pottencial (somente para nosso próprio quadro de funcionários).
2.22	Sua empresa subcontrata outros agentes de tratamento?	**Não subcontratamos agentes de tratamento** *de dados da Pottencial*. A infraestrutura (PaaS/IaaS) pode operar sobre provedores de Cloud de alto nível (ex. AWS/GCP), os quais atuam como subprocessadores de base em Acordo de Confidencialidade (SOC2 e conformidade LGPD).
2.23	Sua empresa garante que seus contratados e subcontratados estão trabalhando de acordo com as determinações da LGPD?	**Sim.** Nossos provedores de cloud (AWS/GCP/Azure) possuem total compliance formal com a LGPD e padrões mundiais.
2.24	Sua empresa possui algum processo para analisar as finalidades e propósitos para os tratamentos de dados pessoais?	**Sim.** O processo de "Privacy Assessment" no ciclo de desenvolvimento seguro revisita as bases legais sempre que uma nova feature com potencial impacto analítico é idealizada.

---

3. Segurança - Governança

ID	Pergunta	Resposta Sugerida
3.1	Sua empresa possui uma área e/ou responsável pela Segurança da Informação?	**Sim.**
3.3	A empresa possui uma política de segurança da informação aplicável a todos os níveis hierárquicos?	**Sim.** *(Upload do arquivo de Evidência:* `politica_seguranca_informacao`*).*
3.5	A política foi divulgada para todos os profissionais da empresa?	**Sim.**
3.7	A política possui informações sobre	**Sim** (Item 4 da Política de Segurança).

	classificação de informações?	
3.8	A política possui informações sobre armazenamento (backup) e descarte?	**Sim** (Item 8 da Política de Segurança).
3.9	A política possui informações sobre controle de antivírus?	**Sim.**
3.10	A política possui informações sobre boas práticas para o uso de equipamentos (ativos)?	**Sim.**
3.11	A política possui informações sobre gestão de riscos?	**Sim.**
3.12	A política cita ou faz referência à política de privacidade?	**Sim.**
3.13	Sua empresa possui um processo formal de gestão de incidentes.	**Sim.** *(Ver anexo de Gestão de Incidentes: `plano_resposta_incidentes`)*.
3.14	Sua empresa possui um plano de resposta a incidentes de segurança da informação?	**Sim.**
3.15	O processo de gestão de incidentes contempla dados pessoais?	**Sim.** Apesar de não haver tratamento em repouso, casos de violação de fluxo engatilham o alerta de vazamento e a imediata notificação ao Controlador.
3.16	Sua empresa possui processo e rotinas de auditorias em seus sistemas?	**Sim.** Os logs de acesso privilegiados são continuamente auditados e avaliados.
3.17	Sua empresa possui procedimento de backup e armazenamento de informações?	**Sim.** Realizamos backup de nossas configurações sistêmicas ("config-state") para rápida restauração do Gateway em caso de disaster recovery. (Nenhum dado do cliente é passível de backup pois transita de forma efêmera).
3.18	Sua empresa possui ferramentas de segurança que auxiliam na proteção de dados?	**Sim** (Criptografia, WAF, controles IAM estritos TLS 1.2+).

3.19	Sua empresa possui uma política para uso seguro de dispositivos móveis ou notebooks?	**Sim.**
3.20	Sua empresa possui uma política de acesso seguro à VPN?	**Sim.**
3.21	A empresa possui a certificação ISO/IEC 27001?	**Não possuímos** o certificado ISO formal, no entanto, nossas políticas administrativas e arquitetura tecnológica são desenhadas respeitando amplamente as diretrizes, frameworks de controles ISO 27001 e CIS Controls.
3.23	A empresa possui certificação PCI-DSS?	**Não aplicável.**
3.25	O Data Center onde os dados estão armazenados possui certificação SOC2?	**Sim.** (A infraestrutura reside em AWS / GCP / Azure).

---

4. Segurança - Identidades de Acesso

ID	Pergunta	Resposta Sugerida
4.1	Sua empresa possui soluções tecnológicas relacionadas à Gestão de Identidade e Acesso (IAM)?	**Sim.** Acessos administrativos à infraestrutura do sistema são orquestrados sistematicamente via Provedores de Identidade (IdP) baseados na nuvem.
4.3	Sua empresa controla e não permite o uso de contas compartilhadas?	**Sim.** Todo acesso a sistemas internos exige autenticação individual atrelada ao e-mail corporativo.
4.4	Sua empresa força a alteração de senha no primeiro login?	**Sim.**
4.5	Sua empresa possui bloqueio de multisessões?	**Sim.**
4.6	Sua empresa pratica padrões de senhas complexas?	**Sim** (Mínimo de 12 caracteres, alfanumérico com símbolos e imposição de MFA - Multi-Factor Authentication obrigatório).
4.7	Sua empresa possui processo formalizado de concessão, alteração e revogação de acessos?	**Sim.** Baseado e atrelado ao ciclo de vida do funcionário ou parceiro (Onboarding / Offboarding) gerenciado pelo setor interno de TI/RH.
4.8	Sua empresa possui processo ... para usuários privilegiados?	**Sim.** Atores com acesso administrativo global requerem processo de elevação temporária (ex. Privileged Access Management) justificada e logs auditados.

4.9	Sua empresa evita o uso de contas genéricas ou as identifica?	**Sim.** Contas de sistema (service accounts) não possuem login interativo permitido para senhas comuns humanas (somente tokens de uso restrito).
4.10	Sua empresa possui processo para criação de contas de serviço e usuário de aplicação?	**Sim.** Através de rotinas de CI/CD via código de infraestrutura (IaC).
4.11	Sua empresa utiliza cofre de senha para monitorar os acessos concedidos a dados sensíveis?	**Sim.** Utilitários como HashiCorp Vault, AWS Secrets Manager ou gerenciadores de senhas corporativos são utilizados internamente.

---

5. Segurança - Infraestrutura

ID	Pergunta	Resposta Sugerida
5.1	A sua empresa hospedará a solução em qual ambiente tecnológico?	**Infraestrutura de Nuvem Pública ou Plataforma Distribuída Corporativa.** *(Ajustar conforme o modelo de deployment acordado, e.g. Kong Konnect Cloud)*.
5.3	Em qual(is) país(es) os serviços serão processados/hospedados?	**Predominantemente no Brasil (Zonas Cloud sa-east-1)** ou nos EUA, a depender da especificação do serviço cloud.
5.4	Os recursos utilizados serão dedicados para a Pottencial ou compartilhado com demais clientes?	Os painéis de administração possuem estrutura multi-tenant nativa com completo e inviolável isolamento lógico garantido pela provedora do sistema SaaS. Todo o tráfego gerado é segmentado e insulado logicamente (Tenant Isolation).
5.5	O banco de dados do software é dedicado para a Pottencial ou compartilhado?	**Compartilhado/Multi-tenant** (para o cluster de metadados), porém com chaves de segregação criptográfica de tenant na camada da aplicação. **Inexiste armazamento residual dos payloads de dados na DB**.
5.7	O sistema/software permite que seja realizada conexão via HTTPS?	**Sim.** Todas as fronteiras operam obrigatoriamente sob TLS.
5.8	O sistema/software possui certificado digital HTTPS?	**Sim.**
5.9	O sistema/software dispõe de APIs para troca de informação?	**Sim.** Sendo a core feature do próprio produto o manuseio e roteamento seguro de APIs.
5.10	O sistema/software possui integração para autenticação com o protocolo SAML 2.0?	**Sim.** (Se tratando do painel de administração da plataforma / IdP).
5.11	A solução que será utilizada possui conexão de Oauth2 ou Openid? Faz	**Sim.** Plenamente suportado pelos Plugins do Gateway (OIDC, OAuth2) para validação

	integração com AzureAD?	corporativa e também para acesso ao Painel de Controle via Azure AD.
5.12	O sistema/software possui mecanismos habilitados para gerar registros e trilhas de auditoria?	**Sim.** "Audit Logs" com rastreio de mutações na infraestrutura e "Access Logs" para os chamados recebidos pelo Gateway.
5.13	Caso a solução esteja exposta para a internet, sua empresa autoriza a área de Segurança da Pottencial a realizar verificações de vulnerabilidade e PenTests?	**Sim.** PenTests autorizados em caixas de homologação controladas, contanto que devidamente programadas e sob NDA, mediante o escopo estrito validado pela área de SecOps da Perceptiva.
5.14	Sua empresa possui processo formalizado para controlar o uso de mídias removíveis?	**Sim.** Bloqueadas administrativamente por política nos eventuais endpoints das equipes críticas. Todos os deploys vão pra a nuvem.
5.15	Estão desabilitados os SSL e TLS não seguros (...)?	**Sim.** Aceitamos e forçamos exclusivamente cifra TLS v1.2 ou TLS v1.3.

---

6. Segurança - Redes

ID	Pergunta	Resposta Sugerida
6.1	A empresa possui soluções tecnológicas relacionadas a Firewall?	**Sim.** Network Firewalls (Security Groups em cloud), regras granulares egress/ingress e Web Application Firewall (WAF) nas fronteiras públicas da infraestrutura.
6.5	A empresa possui segregação de ambiente?	**Sim.** Ambientes isolados (Nuvem / Redes Virtuais / Subredes) para Desenvolvimento (DEV), Qualidade/Homologação (QA/UAT) e Produção (PRD).
6.7	A empresa possui soluções de Filtragem Web?	**Sim.** Nas redes internas corporativas são limitados acessos a websites maliciosos a partir da proteção EDR.
6.8	A empresa possui soluções relacionadas a DLP?	**Não formalizado**, uma vez que o cerne tecnológico do Gateway não lê estruturalmente pacotes opacos de payload para interceptação textual de conteúdo corporativo.
6.9	A empresa possui CASB?	**Não aplicável** ao escopo da entrega técnica provida à Pottencial.
6.10	A empresa possui Antivírus, Anti-Malware?	**Sim.** Ferramentas de XDR/EDR avançadas (como Crowdstrike, SentinelOne, Carbon Black, ou Microsoft Defender) implementadas em 100% dos ativos corporativos.
6.12	A empresa possui criptografia de dados em desktops e notebooks dos profissionais?	**Sim.** Discos corporativos obrigatoriamente encriptados (via FileVault macOS ou BitLocker Windows).
6.13	Sua empresa gerencia e utiliza padrões fortes de segurança	**Sim.** Uso de WPA2/WPA3 enterprise baseados em certificados limitados aos funcionários da companhia, com

	nas redes Wifi?	rota da infraestrutura "guest" totalmente isolada da intranet.
6.14	É garantido que nenhuma interface de administração seja acessada diretamente da Internet?	**Sim.** Ambientes de gerência estão contidos em redes fechadas (VPCs), acessíveis exclusivamente através de túneis autenticados de ponta a ponta sem IP Público.
6.15	Sua empresa limita o uso de ferramentas administrativas como SSH, RDP aos servidores?	**Sim.** Infraestrutura moderna é imutável contêinerizada (Kubernetes / ECS). Em raros cenários de instâncias, o acesso via SSH é totalmente restrito à Bastion Hosts logados. RDP não é utilizado para servidores.
6.16	O acesso aos servidores é restrito apenas aos usuários com funções administrativas de TI?	**Sim.** Apenas equipe autorizada SRE / DevOps.
6.17	Para realizar acesso ao sistema/recurso será necessário utilização de VPN?	**Sim** (Zero Trust Network Access - ZTNA ou VPN forte exigida da equipe técnica de Infra).

---

7. Segurança - Gestão de Vulnerabilidades

ID	Pergunta	Resposta Sugerida
7.1	A empresa contrata e/ou realiza Testes de Intrusão (PenTest)?	**Sim.** Realizado periodicamente sobre o painel das aplicações críticas da gerência B2B.
7.3	A empresa possui soluções relacionadas à detecção e tratamento de Vulnerabilidades?	**Sim.** Scanners integrados no ciclo contínuo de esteira (CI/CD). Ferramentas como Trivy e Clair/Snyk rastreiam as imagens dos repósitos estáticos; adicionalmente o Dependabot age ativamente para a renovação e correção de bibliotecas Open-Source.
7.4	Descreva o processo e a recorrência de aplicação de patches.	Processo de "Patch Management" contínuo. Atuamos dinamicamente (SLA < 48h) de forma ininterrupta à produção "Zero-Downtime" no surgimento de alertas (CVEs emergenciais de severidade Alta/Crítica). Patches medianos são acumulativos a cada Sprint (~14 dias).

---

8. Segurança - Monitoramento de Eventos

ID	Pergunta	Resposta Sugerida
8.1	A empresa possui soluções tecnológicas relacionadas ao SIEM?	**Sim.** Agregação e monitoramento de Access Logs provimento de nuvem nativo aliado a mecanismos modernos de observabilidade e painéis (Prometheus/Grafana/Datadog/Elastic).

8.2	Descreva o processo para monitoramento de eventos de segurança.	O tráfego métrico é rastreado por painéis centrais 24/7. Com a parametrização de limites anormais de chamadas, o software deflagra alertas imediatos às ferramentas de triagem do on-call da equipe SecOps/NOC para apuração e correção imediata.
8.3	A sua empresa possui a ciência de que para problemas e incidentes de segurança (...), a Pottencial deve ser acionada o mais rápido possível?	**Sim**, estamos absolutamente cientes da prioridade da notificação.

---

9. Segurança - Desenvolvimento Seguro

ID	Pergunta	Resposta Sugerida
9.1	A empresa possui política e práticas de desenvolvimento seguro (SDLC)?	**Sim.** *(Ver documento de Procedimentos de Desenvolvimento Seguro: `procedimento_desenvolvimento_seguro...`).*
9.3	A empresa faz uso de soluções para (...) SAST, DAST e SCA?	**Sim.** Scanners Estáticos (SAST) inseridos nos repositórios como parte dos Checks; e Analisadores de composição da dependência (SCA).
9.4	É realizada modelagem de ameaças a cada mudança/alteração de design?	**Sim.** Modelagem requerida para grandes modificações arquiteturais do software base (Architecture Decision Records - ADRs revisados).
9.5	Existe controle e versionamento dos códigos?	**Sim**, via Git em repositórios estritamente privados com proteções de branch e verificação por código de parceiros obrigatória.
9.6	A comunicação entre os componentes (...) são autenticadas?	**Sim.** Microsserviços empregam Malha de Serviço (Service Mesh - mTLS) o que garante uma abstração de rede hermética.
9.7	Os controles de acesso são validados pelo backend ou pelo cliente?	Todos os controles de validações sistêmicas ocorrem diretamente no **Backend** (Edge Computing ou API Gateway) inibindo a premissa de um cliente inseguro.
9.8	As integrações sistêmicas são realizadas através de API?	**Sim.** Arquitetura 100% orientada a eventos e API first.
9.11	Há dados sensíveis expostos nas chamas das URLs das APIs (...) API key, form parameters?	**Não.** Todo token, API Key e parâmetros sensíveis obrigamos a tramitar internamente pelos Headers Authorization segurados pela camada TLS e jamais constam nas URLs.

9.12	Os serviços publicados estão obedecendo aos (...) GET, POST, PUT?	**Sim**, arquitetura baseada aos cânones do protocolo padrão de design RESTful API.
9.14	Há algum processo de mitigação contra ataques de força bruta...?	**Sim.** Bloqueio automático no portal pelo número sucessivo de senhas e a infraestrutura implementada conta com Rate Limiting Avançado e Web App Firewall (WAF) contra bots de varredura.

---

10. Segurança - Dados

ID	Pergunta	Resposta Sugerida
10.1	Descreva como sua empresa utilizará os dados da Pottencial e de seus clientes.	A Perceptiva utilizará puramente a *Telemetria, Rotas de Endpoints (IP Origem/IP Destino) cifrados e os Códigos HTTP de Retorno* apenas para fins operacionais analíticos voltados estritamente à eficiência da latência técnica e prestação pontual de suporte (API Management). Nenhum Dado Pessoal dos segurados é retido.
10.2	Descreva como será realizado o descarte dos dados da Pottencial e de seus clientes após a rescisão do contrato.	Diante da desativação formal da plataforma ("Offboarding" contratual), ocorre a revogação de todos os acessos do Painel do Gestor Pottencial e uma instrução irreversível à destruição por encriptamento no disco de nuvem da configuração local ("Workspaces" do Gateway e chaves operacionais do "Dataplane"), não sobrando informações operacionais da arquitetura de APIs em nossos domínios lógicos.

---

11. Termo de Responsabilidade

ID	Pergunta	Resposta Sugerida
11.1 a 11.5	Aceite/Termos (NDA, Auditorias periódicas, Marco civil/LGPD/Susep 638, Autorização à área de SI Pottencial, Documentação)	**Sim (Para todas de 11.1 a 11.5).** Conformidade total, atestado sob Acordo Confidencial vigente (NDA). Ciência integral das responsabilidades regulatórias da infraestrutura perante a Susep e LGPD para o compromisso arquitetural do privacy-by-design.